SIMATS ENGINEERING

ASSESSMENT TOOL 3 | CO2 – AT3

Course Name	Ethical Hacking
Course Code	ITA1409
Course Outcome	CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks. (BT4)
Student Name / Reg No	B Kirthanaa / 192324244
Assessment	Scenario-Based Assessment

Question 1 Footprinting Tools – Conducting Competitive Intelligence

Question: A consultant must perform a passive security assessment of Example Corp by collecting only publicly available information, without directly interacting with the company's servers. Apply suitable footprinting tools to identify (a) domain registration details, (b) employee email addresses, (c) technology stack and (d) publicly exposed sub-domains, and explain how each tool helps competitive intelligence.

1. Understanding the Scenario

In this scenario I am a cybersecurity consultant hired by Example Corp to check how much information about the company is visible to the public. The work is passive footprinting. This means I gather data only from public sources such as registries, search engines, certificate logs and archives, and I do not send probing traffic to the company's own servers. The aim is to see the company the way an attacker or a business competitor would see it from outside.

Facts given in the question

- The assessment is passive, so no direct interaction with Example Corp' servers.
- Only publicly available information may be collected.
- Four items must be found: domain registration details, employee email addresses, technology stack and exposed sub-domains.

Facts that are not given

The question does not give the real domain name, the company size, or the hosting provider. So I use example.com as a placeholder domain, and the outputs in this answer are illustrative samples, not real data.

2. Key Issues Identified

- **Information leakage:** Public records can reveal staff names, e-mail formats, software versions and forgotten test systems.
- **Stay passive:** Tools must be used in a mode that reads third-party data only (WHOIS servers, search engines, certificate logs), so the target's servers are never touched.
- **Authorisation and ethics:** Even passive work needs a written agreement, and personal data such as employee e-mails must be handled carefully.
- **Competitive value:** The same data tells a competitor about the company's technology choices, size and partners, so it is also a business risk.

3. Tool Selection Summary

Information needed	Tool selected	What the tool does	Competitive intelligence value
Domain registration details	WHOIS / ICANN Lookup	Queries registry and registrar databases for owner, dates, registrar and name servers	Shows company age, registrar, renewal date and DNS provider; reveals related domains
Employee email addresses	theHarvester (with Hunter.io)	Collects e-mails and names from search engines and public sources	Reveals e-mail format, key departments and staff names for later social-engineering risk
Technology stack	WhatWeb / BuiltWith / Wappalyzer	Reads public web page headers, scripts and meta tags to identify software and versions	Shows the CMS, server, language and libraries; helps spot outdated software
Exposed sub-domains	Amass (passive) / crt.sh	Collects sub-domain names from certificate logs, archives and DNS datasets	Reveals dev, staging and test systems, new products and hosting partners

4. Applying the Tools

4.1 Domain Registration Details – WHOIS Lookup

WHOIS is a public query protocol that returns registration data for a domain. From it I note the registrant organisation, registrar, creation and expiry dates, name servers and domain status. Many registrars now hide personal contact details, but company name, country and name servers usually remain visible.

Command used: `whois example.com`



Figure: WHOIS output showing registrar, dates, name servers and registrant organisation (illustrative)

What this tells me: The domain was created in 2014, so the company has been online for more than a decade. The name servers (ns1 and ns2) are hosted on the company's own domain, which means the company runs its own DNS. This leads to the zone transfer check in Question 2. DNSSEC is shown as unsigned, which is a small security gap I will note in the report.

Competitive intelligence use: A competitor can use registration dates and registrar data to judge how mature the company is, find other domains owned by the same registrant (for example new product or brand domains), and see when domains will expire.

4.2 Employee Email Addresses – theHarvester

theHarvester is an open-source intelligence tool that gathers e-mail addresses, host names and employee names from public sources such as search engines and certificate transparency data. When only passive sources are selected, nothing is sent to the target's servers.

Command used: `theHarvester -d example.com -b duckduckgo,crtsh,hunter -l 200`

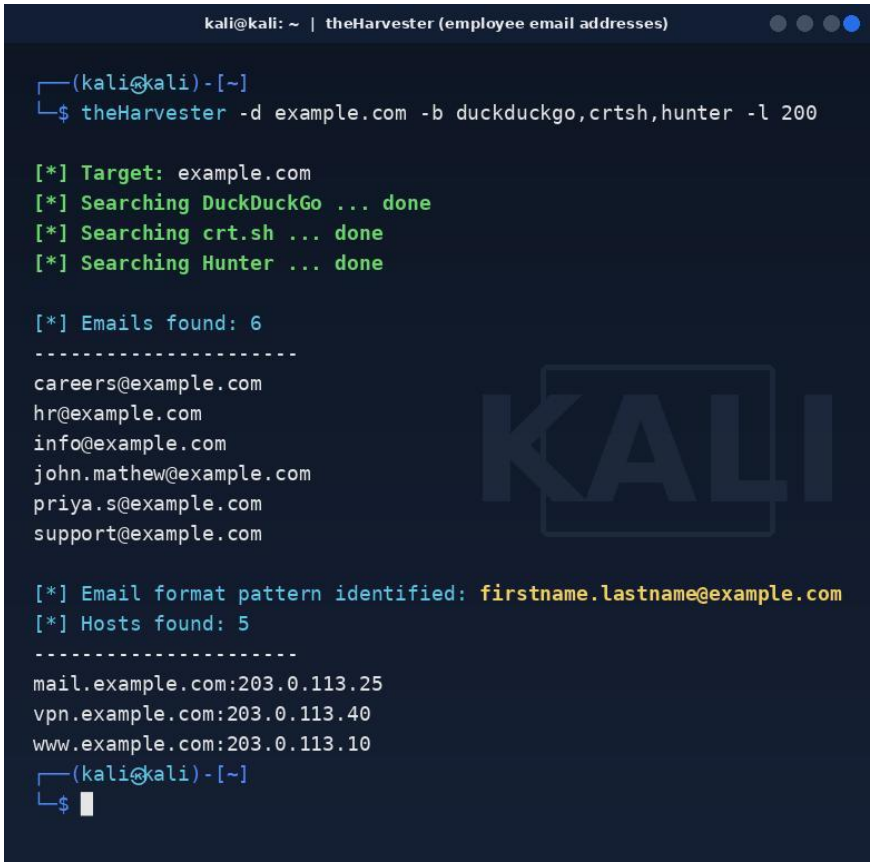


Figure: theHarvester results with discovered e-mail addresses and the company e-mail format (illustrative)

What this tells me: Six addresses were found, and two of them (john.mathew and priya.s) are personal names. The pattern firstname.lastname@domain allows anyone to guess further staff addresses. Role addresses such as hr@ and careers@ show which departments exist.

Competitive intelligence use: E-mail patterns and job-related mailboxes show the company structure and hiring activity. For the security report, this is a warning: an attacker could use the same list to target staff with phishing, which links directly to Question 3.

4.3 Technology Stack – WhatWeb / BuiltWith / Wappalyzer

Web technology profilers read what a normal visitor's browser already receives: HTTP headers, HTML meta tags, cookies, script file names and page structure. From these they identify the web server, programming language, content management system and libraries. BuiltWith and Wappalyzer give the same result

through a website or browser plug-in without any command line, and they also keep history of earlier technologies.

Command used: `whatweb -v www.example.com`

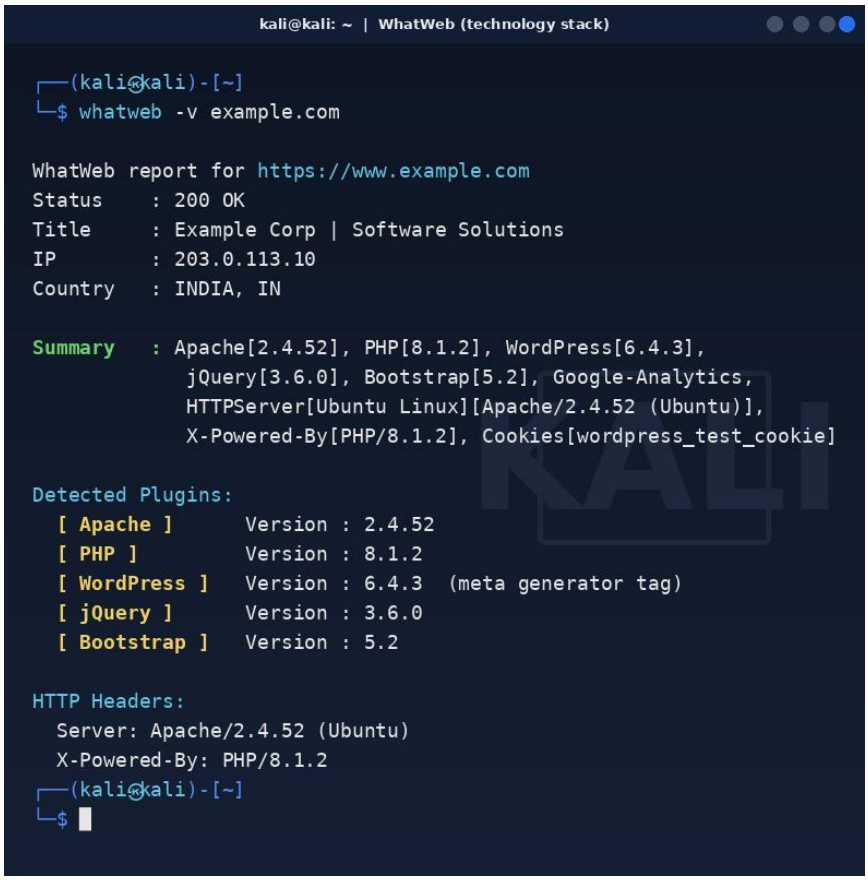


Figure: WhatWeb output identifying server, language, CMS and libraries with versions (illustrative)

What this tells me: The site runs on Apache 2.4.52, PHP 8.1.2 and WordPress 6.4.3 with jQuery and Bootstrap. Exact version numbers are visible in headers. If any version is old, public vulnerability databases such as CVE lists would show known weaknesses, so the finding is recorded as 'unnecessary version disclosure'.

Competitive intelligence use: A competitor learns which CMS, analytics and front-end tools the company uses, how modern its stack is, and which vendors it depends on.

4.4 Publicly Exposed Sub-domains – Amass (passive) and crt.sh

Sub-domains show every service the company has put online. Amass in passive mode combines many public data sources such as certificate transparency logs, web archives and DNS datasets, and does not query the target's DNS servers directly. The website crt.sh can also be searched manually for certificates issued to the domain.

Command used: `amass enum -passive -d example.com`

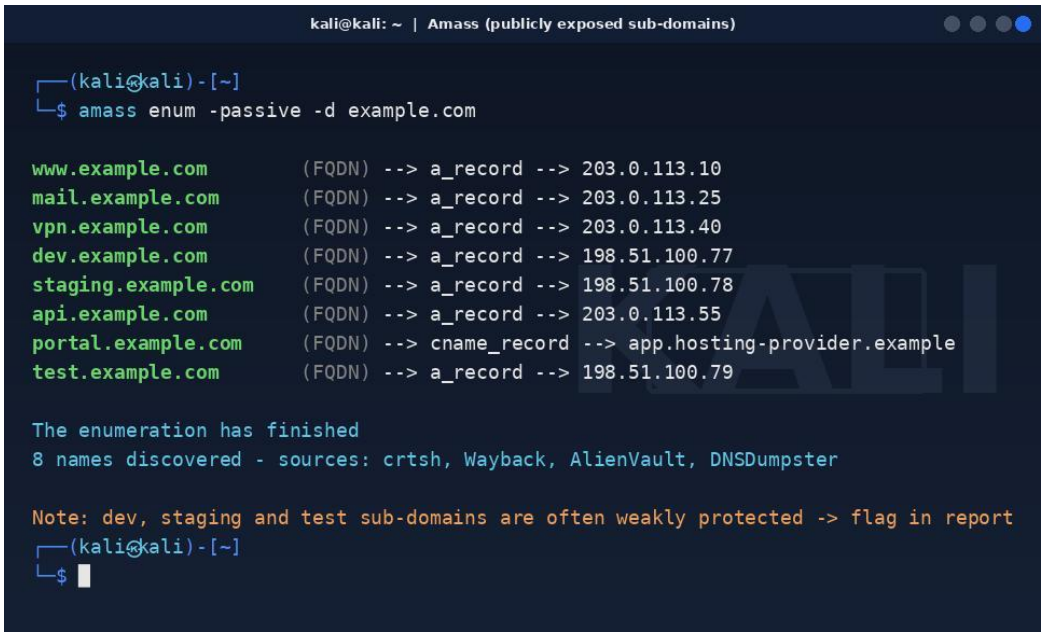


Figure: Passive sub-domain enumeration listing www, mail, vpn, dev, staging, api, portal and test (illustrative)

What this tells me: Eight sub-domains are public. The names dev, staging and test are important because development systems are often less protected than production. The vpn sub-domain shows how remote staff connect, and portal points to a third-party hosting provider.

Competitive intelligence use: Sub-domain names can reveal upcoming products (for example a new api or beta site), hosting partners and the overall size of the company's online presence.

5. Workflow of the Passive Assessment

The four tools work together. Each one answers one question, and the results are combined into a single intelligence picture.

6. How Footprinting Supports Competitive Intelligence

Competitive intelligence means collecting legal public information to understand a business, its strategy and its technology. Footprinting tools provide the technical side of this. The table compares what a competitor and a security consultant each gain from the same data.

Data collected	Gain for a competitor	Gain for the security team
WHOIS records	Company age, related domains, DNS provider	Spot domain expiry risk, missing DNSSEC, look-alike domains
E-mail addresses	Organisation structure, departments, hiring	Know phishing exposure; plan awareness training
Technology stack	Vendors and tools in use, level of modernisation	Find outdated versions and unnecessary disclosure
Sub-domains	New products, partners, hosting choices	Find forgotten dev/test systems and shadow IT

7. Ethical and Legal Points

- Keep the work passive and inside the signed scope. Written authorisation is required before the assessment.
- Use only public sources. Do not log in, guess passwords or scan the company's servers during this phase.
- Treat employee names and e-mail addresses as personal data. Collect only what is needed, store it securely and share it only with the client.
- Report all findings privately to the client, with recommendations such as hiding version banners, removing unused sub-domains and limiting public e-mail exposure.

8. Conclusion for Question 1

WHOIS gives the registration details, theHarvester gives employee e-mail addresses, WhatWeb or BuiltWith gives the technology stack, and Amass with crt.sh gives the exposed sub-domains. All four work through public sources, so the assessment stays passive. Together they show how much a competitor or attacker can learn about Example Corp without touching its servers, and they give the company a clear list of exposures to reduce.

Question 2 : DNS Zone Transfers

Question: During an authorised penetration test, an analyst suspects the target's DNS server is misconfigured and may allow unauthorised zone transfers. Apply the appropriate DNS command or tool to verify this. If the transfer succeeds, explain how the records help identify internal hosts, mail servers and sub-domains.

1. Understanding the Scenario

A DNS zone is the complete list of records for a domain, such as A records (host to IP), MX records (mail servers), NS records (name servers) and CNAME records (aliases). A zone transfer (AXFR) is a normal feature that lets a primary DNS server copy this full list to its secondary servers so that all servers stay in sync. The problem appears when the primary server answers AXFR requests from anyone. Then an outsider can download the entire zone in one request.

Facts given in the question

- The test is authorised, so active DNS queries to the target's name servers are allowed.
- The analyst only suspects a misconfiguration; it has not been confirmed.
- If the transfer works, the records must be used to identify internal hosts, mail servers and sub-domains.

Facts that are not given

The real domain, the name servers and the DNS software (BIND, Windows DNS) are not given. I use example.com with name servers ns1 and ns2 as a lab example, and the outputs are illustrative.

2. Why Zone Transfer Misconfiguration Is Risky

Without a zone transfer an attacker has to guess sub-domains one by one. With a successful transfer the attacker gets everything at once, including host names that were never meant to be public. Names such as db01, fileserver or hr-portal show where the valuable systems are, and private IP addresses (10.x.x.x) reveal the internal network layout. This saves the attacker a great deal of time and noise during reconnaissance.

3. Steps to Verify Zone Transfer

Step 1 – Find the authoritative name servers

A zone transfer must be requested from a server that is authoritative for the domain, so the first step is to list the NS records.

Command used: `dig NS example.com +short`

Step 2 – Request the zone from each name server

Each name server is tested separately, because one server may be secure while another is not. The dig command with the AXFR type sends the transfer request over TCP port 53.

Command used: `dig AXFR example.com @ns1.example.com`

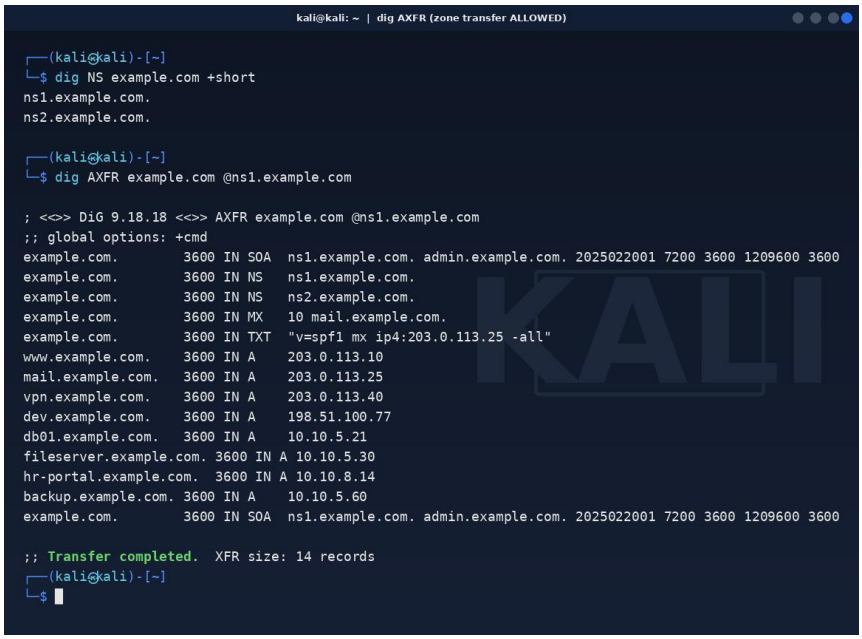


Figure: dig AXFR succeeds on ns1 and returns the full zone (illustrative, misconfigured server)

Result: ns1 returned the whole zone (14 records, ending with the same SOA record it started with). This confirms the server allows transfers to unauthorised hosts.

Step 3 – Test the other name servers

The same request is sent to ns2. A secure server replies with a refusal. The host command is an alternative that gives the same check.

Commands: `dig AXFR example.com @ns2.example.com` or `host -t axfr example.com ns2.example.com`

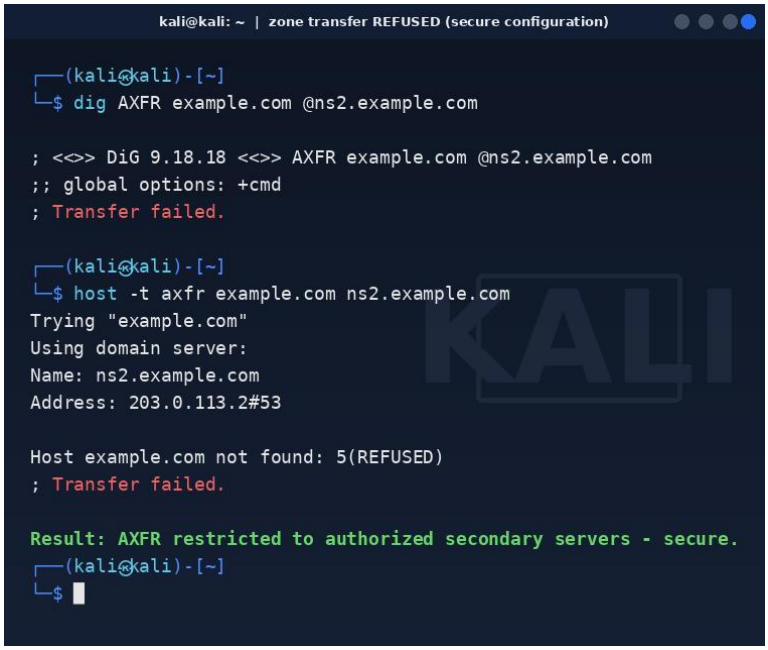


Figure: ns2 refuses the transfer, which is the correct secure behaviour (illustrative)

Step 4 – Automate and save the result

DNSRecon can run the whole check in one command. It finds the NS records, tries a transfer on each, and saves the records to a file that can be added to the evidence. nmap with the dns-zone-transfer script and fierce are other tools that do the same job.

Command used: `dnsrecon -d example.com -t axfr`

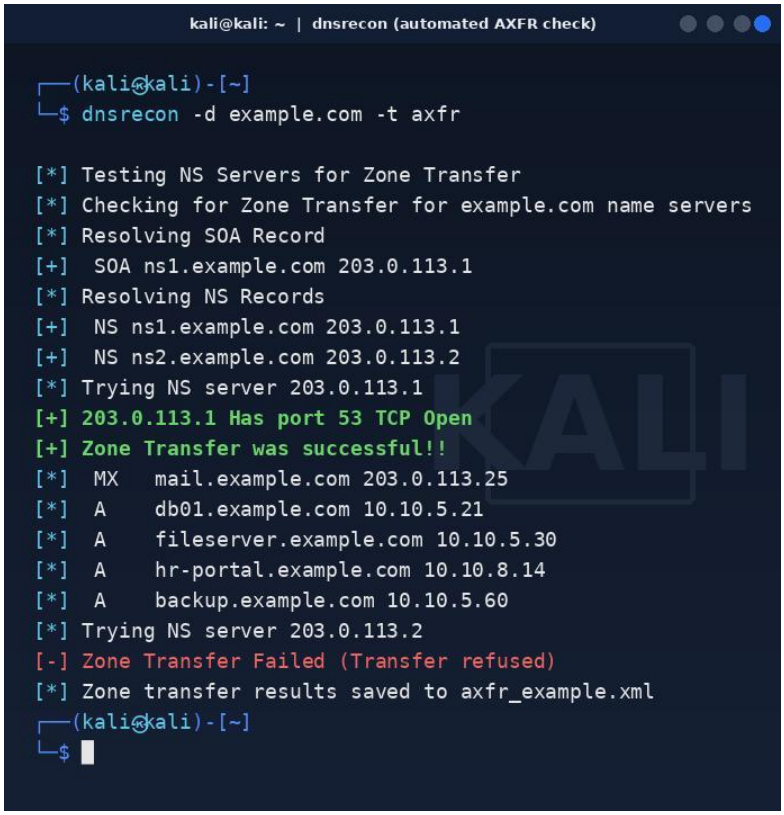


Figure: DNSRecon confirms a successful transfer on ns1 and a refusal on ns2 (illustrative)

4. Using the Retrieved Records in Reconnaissance

Once the zone is downloaded, each record type gives a different piece of information. The table maps the sample records from the zone transfer output to what the tester learns.

Record type	Sample record	What it reveals	How it is used
A	db01 → 10.10.5.21; fileserver → 10.10.5.30; hr-portal → 10.10.8.14; backup → 10.10.5.60	Internal hosts and private IP ranges	Maps the internal network and picks high-value targets (databases, file and backup servers)
A / CNAME	www, vpn, dev, api (public IPs)	Public-facing hosts and sub-domains	Builds the attack surface list; dev and test hosts get priority checks
MX	10 mail.example.com	Mail server and its priority	Identifies the mail gateway; helps plan e-mail security and spoofing tests
NS	ns1, ns2	DNS servers	Shows which servers to test for further DNS issues
TXT	v=spf1 mx ip4:203.0.113.25 -all	SPF policy and authorised mail sender	Shows how strict anti-spoofing is; useful for the phishing risk in Question 3
SOA	serial 2025022001, admin contact	Primary server, admin contact, zone version	Shows who manages DNS and how often it changes

4.1 Identifying internal hosts

Records that point to private addresses (10.10.5.x and 10.10.8.x) show that internal names have leaked into the public zone. The naming also shows the purpose of each machine: db01 is a database, fileserver stores documents, backup holds backups and hr-portal serves HR staff. In a real test I would list these as sensitive assets and recommend that internal records be moved to a separate internal DNS zone (split-horizon DNS).

4.2 Identifying mail servers

The MX record gives the mail server mail.example.com at 203.0.113.25. The SPF record in the TXT entry confirms that only this IP is allowed to send company mail. This tells the tester which server handles e-mail, so mail filtering, open relay checks and spoofing protection can be reviewed within scope.

4.3 Identifying sub-domains

The zone lists every sub-domain, including those that never appeared in public search results. Compared with the passive result in Question 1, the zone adds db01, fileserver, hr-portal and backup, which passive tools could not find. This shows why zone transfer is far more complete than guessing or passive collection.

5. Recommended Countermeasures

- Restrict transfers to named secondary servers only, for example `allow-transfer { 203.0.113.2; };` in BIND, or the 'only to listed servers' option in Windows DNS.
- Protect transfers with TSIG keys so that only authenticated servers can request a zone.
- Use firewall rules to allow TCP port 53 only between the DNS servers.
- Keep internal host names in an internal-only zone and never in the public zone.
- Monitor DNS logs for AXFR requests from unknown IP addresses and alert on them.

6. Ethical and Legal Points

The test is authorised, so the AXFR requests are allowed. The tester should still request the zone only once per server, avoid repeated requests that could load the DNS server, store the downloaded zone file securely, and report the misconfiguration to the client without delay because attackers can run the same command at any time.

Practice tip: For a hands-on lab, the domain zonetransfer.me is intentionally provided for practising zone transfers, so students can test these commands legally.

7. Comparison: Vulnerable vs Secure DNS

Aspect	Vulnerable server (ns1)	Secure server (ns2)
AXFR request from tester	Full zone returned	Refused
Information exposed	Internal hosts, mail servers, all sub-domains	None beyond normal public lookups
Configuration	allow-transfer set to any	allow-transfer limited to secondary IP, TSIG enabled
Risk level	High – major reconnaissance gain for attackers	Low

8. Conclusion for Question 2

The correct way to verify the issue is to find the name servers with dig NS and then request the zone from each one with dig AXFR (or host -t axfr or dnsrecon). In this example ns1 returned the full zone and ns2 refused. The retrieved records expose internal hosts, the mail server and every sub-domain, which makes later testing much easier. The fix is to limit transfers to authorised secondary servers, use TSIG authentication and keep internal names out of public DNS.

Question 3: Social Engineering Attacks and Countermeasures

Question: Employees receive an email claiming to be from the IT department, asking them to verify their login credentials through a link because of an urgent security update. Identify the type of social engineering attack and apply countermeasures employees should follow before responding. Explain how these actions prevent credential theft.

1. Understanding the Scenario

Social engineering attacks trick people instead of breaking technology. In this scenario several employees receive the same e-mail that appears to come from the IT department. It says there is an urgent security update and asks the employee to enter login details on a web page reached through a link. The attacker's goal is to collect usernames and passwords and then use them to enter the company network.

Facts given in the question

- The e-mail claims to be from the IT department.
- It asks employees to verify login credentials through a provided link.
- It uses an urgent security update as the reason.

2. Type of Attack Identified

This is a **phishing attack**, more precisely credential-harvesting phishing that uses **pretexting** (impersonation of the IT department). The reasons are listed below.

- **Phishing:** a fraudulent e-mail is sent to many people and contains a link to a fake login page. Because the e-mail goes to all employees and is not personalised for one person, it is regular (bulk) phishing and not spear phishing.
- **Pretexting / impersonation:** the attacker pretends to be a trusted internal team, which is a made-up reason (pretext) for asking for credentials.
- **Authority and urgency:** employees tend to obey the IT department, and the 'urgent' deadline reduces careful thinking.
- **Fear and scarcity:** the threat that the account will be locked pushes people to act quickly.

Related attack	Method	Matches this scenario?
Phishing	Bulk e-mail with fake link	Yes – main type
Spear phishing	Personalised e-mail to one target	No – the e-mail is generic
Vishing	Voice call pretending to be IT	No – e-mail used
Smishing	SMS with fake link	No – e-mail used
Whaling	Targets senior executives	No – all employees targeted

3. Warning Signs in the E-mail

- **Sender mismatch:** the display name looks internal but the Reply-To address belongs to an outside domain.
- **Urgent and threatening language** such as 'within 24 hours' or 'account will be locked'.
- **A request for credentials by e-mail.** Real IT teams do not ask for passwords through links.
- **Link mismatch:** the visible text shows the company portal but the real URL goes to a different domain, often without HTTPS.
- **Generic greeting** ('Dear Employee') and a 'do not reply' note that discourages checking.

Email headers give technical proof.

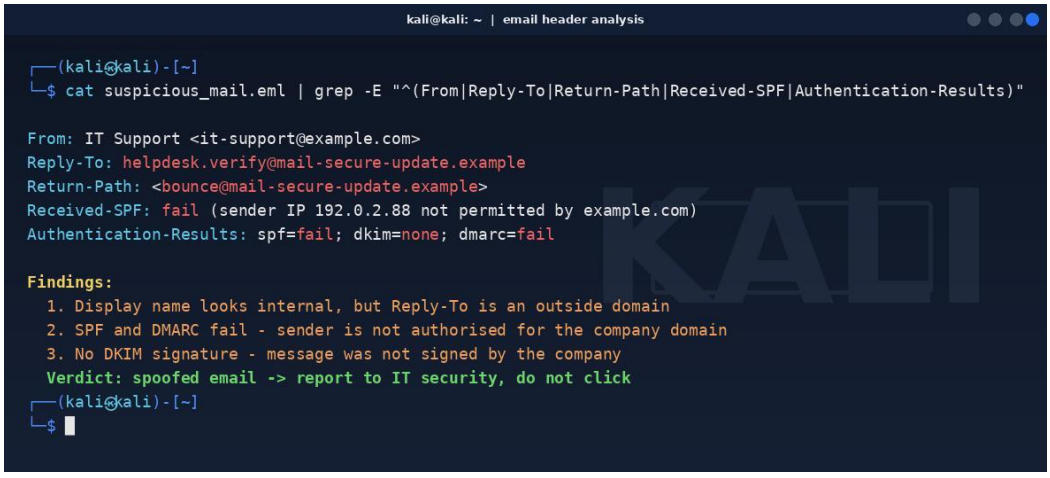


Figure: Header analysis showing SPF/DMARC failure and a different Reply-To domain (illustrative)

4. Countermeasures Employees Should Follow Before Responding

Employees should follow these steps in order, before clicking anything or replying. Each step stops the attack at a different stage.

No.	Countermeasure	What the employee does	How it prevents credential theft
1	Stop and think	Pause when an e-mail is urgent or asks for a password	Removes the pressure that attackers rely on
2	Verify the sender	Check the full address and Reply-To, not only the display name	Exposes spoofed or look-alike senders
3	Inspect the link	Hover over the link to see the real URL; check domain spelling and HTTPS; do not click	Stops the user from reaching the fake login page
4	Never share credentials	Do not enter or send passwords through an e-mail link	Even if the page is opened, no password is handed over
5	Confirm through another channel	Call the IT help desk using the official number, or open the company portal by typing the address	Confirms whether the request is real using a trusted route
6	Report	Use the 'Report phishing' button or forward to the security team	Lets IT block the sender and warn other staff quickly
7	Use MFA	Keep multi-factor authentication enabled	A stolen password alone is not enough to log in
8	Act fast if clicked	Change the password at once, tell IT and let them check the account	Limits the time the attacker can use the stolen password

5. How These Actions Prevent Credential Theft

Credential theft needs three things: the victim must trust the e-mail, must open the fake page and must type the password. The countermeasures remove each of these.

- **Breaking trust:** checking the sender and header shows that the message is not from IT, so the story collapses.
- **Breaking the click:** hovering over links and avoiding them keeps the victim away from the fake page where credentials are captured.

6. Organisation-Level Countermeasures

Employee habits are the last line of defence. The organisation should also support them with technical and policy controls.

Control	Purpose
E-mail security gateway	Filters known phishing, flags external senders and scans links
SPF, DKIM and DMARC with reject policy	Stops outsiders from sending mail that pretends to come from the company domain
Multi-factor authentication	Makes stolen passwords far less useful
Security awareness training and phishing simulations	Teaches staff to spot attacks and measures improvement

Control	Purpose
Clear IT communication policy	Staff know that IT never asks for passwords by e-mail or link
Easy reporting channel	Quick reporting helps block the campaign early
Incident response plan	Defines password reset, account review and log checks after a click

7. Practical Example (General Illustration)

- **Unsafe way:** An employee sees the urgent message, clicks 'Verify My Account Now' and types the username and password into a page that looks like the company login. The attacker receives the credentials and logs into the mail system within minutes.
- **Safe way:** The employee notices the Reply-To address is from another domain, hovers over the button and sees a different URL, does not click, and reports the e-mail to the security team. IT blocks the sender domain and sends a warning to all staff, so no credentials are lost.

8. Ethical and Legal Points

If this is simulated as part of an authorised awareness exercise, the organisation must give written approval, use a harmless landing page that does not store real passwords, and avoid blaming individuals. Real phishing is a crime under the Information Technology Act, 2000 (for example Sections 66C and 66D on identity theft and cheating by impersonation), so the exercise must stay inside the agreed rules.

9. Conclusion for Question 3

The scenario is a phishing attack that uses pretexting, authority and urgency to harvest credentials. Employees should pause, verify the sender, inspect the link, never enter credentials through an e-mail link, confirm through an official channel, report the message and keep MFA on. These steps work because they break the attack at each stage: trust, click and password entry. Together with e-mail filtering, DMARC and regular training, they greatly lower the chance of credential theft.